

マネジメントシステム監査

1. 这是系统审计（System Audit）中关于「独立性（Independence）」的核心考题。

在系统审计中，“独立性”是灵魂。其基本原则是：**审计者不能审计自己参与过的业务，也不能审计自己负责的领域。** 必须保持客观，不被利益冲突所左右。

知识点总结

- **审计独立性：** 审计人员必须处于一个不会受到被审计对象干扰的位置，且不应与被审计对象存在直接的利害关系或过往渊源。
- **主要禁忌：**
 - **不能“自查自纠”：** 不审计自己曾经开发或维护过的系统。
 - **不能“部门受限”：** 不由被审计部门的人员直接进行审计。

选项解析与详细说明

我们来依次“审判”各个选项：

- **选项 ア：** “営業部門の要員を監査チームのメンバーに任命し、営業部門における個人情報保護対策についての監査を行わせる”（任命营业部门员工进入审计组，审计营业部门的个人信息保护措施）。
 - **解析：错误。** 审计人员审计自己所属的部门，无法保持客观。
- **选项 イ：** “監査法人からシステム監査人を採用して内部監査人に位置付け、社内の業務システム開発についての監査を行わせる”（从审计法人聘请系统审计师作为内部审计师，审计内部业务系统开发）。
 - **解析：正确答案！** 通过引入外部专业审计人才作为内部审计，由于其与社内部门无利益瓜葛，能有效地保持客观性与独立性。
- **选项 ウ：** “システム部門の要員を監査部門に異動させ、システム部門に所属していたときに開発に参加したシステムの保守についての監査を担当させる”（将系统部门人员调往审计部门，审计其曾经参与开发的系统维护）。
 - **解析：错误。** 所谓的“审计自己开发过的系统”，这是严重的利益冲突，完全丧失了独立性。
- **选项 エ：** “社内の業務システム運用を委託しているITベンダーの監査部門に依頼し、社内の業務システム運用についての外部監査を担当させる”（委托给负责公司系统运营的 IT 供应商的审计部门，进行外部审计）。

- **解析：错误。** 让“被审计对象（IT 供应商）”来审计自己，相当于“裁判员自己给自己打分”，完全没有独立性。

小学生级记忆法

把「审计的独立性」想象成“批改作业”：

- 如果你是老师，你不能让学生给自己写的作业打分（选项 ア）。
- 如果你以前帮学生写过作业，那你现在也不能去给他的作业评分（选项 ウ）。
- 找一个完全不认识这个学生的校外老师（外聘审计师）来打分（选项 イ），这才是最**公正、独立**的！

考试小秘籍

考场机械式判断技巧：

- a. 看到题目问「**独立性 (Independence)**」：
 - b. 脑中迅速闪过这几个词：「**客观 (客観的)**」、「**没有利益冲突 (利害関係がない)**」、「**不参与 (関与しない)**」。
 - c. 只要选项里说“自己部门审计自己”、“审计自己做过的项目”、“审计自己的合作伙伴”，通通视为违规，直接排除！
2. 这道题考查的是「**システム監査 (系统审计)**」的本质对象。

在信息系统审计中，我们审计的对象必须与「**IT (信息技术)**」相关，或者是在业务流程中高度依赖于「**信息系统处理**」的环节。

知识点总结

- **系统审计的关注点：**
 - i. **IT 资源：** 硬件、软件、网络、数据等。
 - ii. **IT 控制：** 系统安全性、可靠性、可用性、数据完整性、运行效率等。
 - iii. **IT 业务依赖：** 那些如果没有信息系统就无法正常运转或保证质量的业务处理流程。

选项解析与详细说明

我们来依次“审判”各个选项，找出哪个是 IT 系统审计的“真命天子”：

- **选项 ア：** “経営企画部が行っている中期経営計画の策定の経緯”（经营企划部制定中期经营计划的经过）。
 - **解析：** 属于纯粹的「经营审计（経営監査）」，侧重于战略决策，而非系统控制。
- **选项 イ：** “人事部が行っている従業員の人事考課の結果”（人事部进行员工绩效考核的结果）。

- **解析：**属于「**人事审计**」，即便使用了评价系统，审计重点也是评价体系的公平性，而非系统本身。
- **选项 ウ：**“製造部が行っている不良品削減のための生産設備の見直し状況”（制造部为减少不良品而对生产设备进行的重组）。
 - **解析：**属于「**生产/业务审计（業務監査）**」，关注的是物理生产流程和设备改进。
- **选项 エ：**“販売部が行っているデータベースの入力・更新における正確性確保の方法”（销售部在数据库输入及更新时确保准确性的方法）。
 - **解析：正确答案！** 这是最典型的系统审计对象。因为涉及「数据库（Database）」、「输入输出（Input/Update）」以及「数据完整性/准确性（Data Integrity）」，这些完全在IT系统审计的职权范围内。

小学生级记忆法

把「系统审计」**想象成**“信息系统的医生”：

- 医生（系统审计师）只检查跟“电脑、数据、软件”相关的病。
- 经营战略（选项 ア）、绩效考核（选项 イ）、工厂流水线（选项 ウ）——这些是公司其他部门的事，医生不管。
- 数据库里的数据乱不乱（选项 エ）——这正是医生最关心的“心脏病”，所以必须审计。

考场机械式判断技巧：

- a. 看到「**システム監査（系统审计）**」：
 - b. 迅速捕捉关键字：「IT」、「データベース（数据库）」、「システム（系统）」、「情報（信息）」、「アクセス権（权限）」、「セキュリティ（安全）」。
 - c. 选项中如果没出现这些“IT 气息”十足的词，那大概率不是系统审计的考点。
 - d. **记住：**系统审计 = 查系统控制的漏洞，而不是查业务本身对不对。
3. 这道题考查的是「**システム管理基準（系统管理基准）**」中，针对「**安全性（Security/Safety）**」维度的具体审计点。

知识点总结

在系统审计中，为了确保系统的“安全性”，核心目标是「防止未授权访问」和「保护数据不被篡改或破坏」。

- **安全性 (Security) 的核心：** 防御外部或内部的非法入侵与滥用。
- **其他维度的核心：**
 - **可靠性 (Reliability)：** 强调系统的持续稳定运行、抗故障能力。
 - **效率性 (Efficiency)：** 强调资源利用率和响应速度。

选项解析与详细说明

我们来逐一分析，看看哪个选项是真正为了防止“不正当使用”而设计的：

- **选项 1：“アクセス管理機能の検証”（访问管理功能的验证）。**
 - **解析：正确答案！** 通过 ID、密码、权限分配等访问控制手段，确保只有经过授权的人员才能执行特定操作，直接针对“不正な使用（不正当使用）”进行防御。
- **选项 2：“フェールソフト機能の検証”（故障弱化功能的验证）。**
 - **解析：**属于“可靠性”范畴。当系统部分发生故障时，限制功能以维持最低限度的运行，防止系统完全崩溃。
- **选项 3：“フォールトトレラント機能の検証”（容错功能的验证）。**
 - **解析：**属于“可靠性”范畴。通过冗余（备份）机制，确保系统在设备故障时仍能正常运行。
- **选项 4：“リカバリ機能の検証”（恢复功能的验证）。**
 - **解析：**属于“可靠性”或“安全性”的后续恢复环节。它关注的是故障或破坏发生后的“修复”，而不是对“不正当使用”的主动防御。

小学生级记忆法

把「安全性审计」想象成“守护保险柜”：

- **アクセス管理（正确答案）：**就是给保险柜加锁，并确认只有拿钥匙的人才能打开。这直接防止了小偷（非法用户）乱动。
- **フェールソフト/フォールトトレラント/リカバリ：**这些都是在“保险柜坏了”或者“东西丢了”之后怎么补救或保持运行的方法，属于“防灾减灾”或“可靠性”范畴，不是“防盗”手段。

考场机械式判断技巧：

- a. 题目如果出现「不正な使用から保護 (防止不正当使用)」或「安全性 (Security)」：
 - b. 迅速锁定与「权限 (権限)」、「ID」、「密码 (パスワード)」、「访问控制 (アクセス制御)」相关的选项。
 - c. 凡是涉及“故障”、“冗余”、“恢复”、“连续运行”的，它们通通归属于「信頼性 (Reliability)」，考试时直接排除即可！
4. 这道题考查的是「内部統制（内部控制）」六大要素中，「統制活動（控制活动）」的核心内涵。

在金融厅的框架下，「統制活動 (Control Activities)」指的是为了将风险控制在可接受范围之内，由管理者通过政策和程序所采取的**具体的、日常的执行手段**。

- **核心逻辑：**它是一种“预防性”或“发现性”的机制，用来确保经营目标实现和资产安全。最经典的手段包括：职责分离、审批授权、实物保护、信息系统控制等。

我们来依次对比这四个选项，寻找属于“控制活动”的具体行为：

- **选项 ア：**“経営者が自らの意思としての経営方針を全社的に明示していること”（经营者向全公司明确传达经营方针）。
 - **解析：**这是「**統制環境 (控制环境)**」的一部分。它是内部控制的基础，反映了管理者的态度和道德价值观。
- **选项 イ：**“情報システムの故障・不具合に備えて保険契約に加入しておくこと”（为应对信息系统故障和缺陷而加入保险合同）。
 - **解析：**这是「**リスクの評価と対応 (风险评估与应对)**」的一部分。是对识别出的风险进行的一种应对措施（风险转移）。
- **选项 ウ：**“内部監査部門が定期的に業務監査を実施すること”（内部审计部门定期开展业务审计）。
 - **解析：**这是「**モニタリング (监控)**」的核心环节。审计是为了评估控制活动是否有效，属于“再控制”或“监督”。
- **选项 エ：**“発注業務と検収業務をそれぞれ別の者に担当させること”（由不同的人分别承担订货业务和验收业务）。
 - **解析：正确答案！**这就是著名的「**職務分掌 (职责分离 / Segregation of Duties)**」。这是典型的“控制活动”，通过让不同的人干不同的事，防止舞弊或误操作。

小学生级记忆法

把「控制活动」**想象成**“厨房的防盗流程”：

- **统制环境：**老板定下规矩，“谁也不准偷吃”（企业文化）。
- **风险评估：**老板觉得材料可能被浪费，所以买了保险（应对风险）。
- **监控：**经理时不时来厨房突击检查（内部审计/监控）。
- **控制活动（正确答案）：**管仓库的人不能管做菜，管买菜的人不能管验收（职责分离）。这是为了让你想偷吃也没机会，通过日常流程强制保证流程正确。

考场机械式判断技巧：

- a. 看到「**統制活動 (Control Activities)**」：
 - b. 迅速寻找以下关键词：「**職務分掌 (职责分离)**」、「**承認 (审批)**」、「**権限設定 (权限设置)**」、「**物理的保護 (物理保护)**」、「**照合 (核对)**」。
 - c. 如果选项里出现“文化”、“方针”、“环境”那是统制环境；出现“审计”、“纠正”、“评估”那是监控或风险评估。
 - d. **控制活动 = 具体且强制的业务操作规范。**
5. 这道题考查的是「**系统设计阶段**」内部控制的有效性。

要降低“利用者要求（用户需求）未能得到满足”的风险，核心在于“确保用户从一开始就参与并确认设计内容”。

知识点总结

- **核心控制点：** 在系统设计阶段，需求方与开发方的“沟通”和“确认”是质量保证的生命线。
- **主要手段：** 需求定义回顾（Review）、原型验证（Prototyping）、用户参与评审。

选项解析与详细说明

我们来依次“审判”这些选项，寻找能够防止“设计与用户需求脱节”的控制措施：

- **选项 1：** “システム設計書に基づき、プログラム仕様書を作成していること”（根据系统设计书编写程序规格书）。
 - **解析：** 这是开发内部的流程，关注的是设计到编程的准确性，与用户需求是否被满足无直接关系。
- **选项 2：** “システムテスト要件に基づいてテスト計画を作成し、システム利用部門の責任者の承認を得ていること”（基于系统测试要求制定测试计划，并获得系统利用部门负责人的批准）。
 - **解析：** 关注的是“测试阶段”的认可，属于事后控制，太晚了。如果在设计阶段需求就错了，到测试阶段再发现，成本会非常高。
- **选项 3：** “プログラミングは定められた標準に従っていること”（编程遵循既定标准）。
 - **解析：** 这是关于编码质量的控制，属于技术规范层面，不能保证功能符合业务需求。
- **选项 4：** “利用部門が参画して、システム設計書のレビューを行っていること”（利用部门参与并对系统设计书进行评审）。
 - **解析：正确答案！** 这就是最有效的控制活动。让用户在设计阶段就介入，直接参与设计书的评审，能确保设计意图与业务需求高度一致，从而从源头上消灭“无法满足需求”的风险。

小学生级记忆法

把“设计阶段的风险”想象成“盖房子”：

- 建筑师（开发人员）画好了蓝图（系统设计书）。
- **选项 4（正确答案）：** 你（利用部门）在蓝图画好后，拿着蓝图仔细看，指着说“这里我想要个窗户，那里厨房位置不对”。你在设计阶段就把错误纠正了，这房子盖出来肯定符合你的心意。
- 其他选项：要么是工人在按蓝图搬砖（选项 1/3），要么是房子盖好了才去验收（选项 2），那时再改，房梁都得拆了！

考试小秘籍

考场机械式判断技巧：

- a. 看到「利用者要件 (用户需求)」 + 「充足 (满足)」：
 - b. 脑中迅速锁定关键词：「参画 (参与)」、「レビュー (评审)」、「合意 (达成一致)」。
 - c. 凡是提到“测试计划”、“编程标准”、“规格书作成”的，这些都属于开发人员的技术环节，无法直接控制“业务需求偏差”这个风险。
 - d. 记住：需求不满足，根源在沟通。所以只要选“让用户参与进来评审”的选项，准没错！
6. BCP (Business Continuity Plan: 事業継続計画) の定義と監査の際の判断基準 (ガイドライン) についての理解は、システム監査やITガバナンスの試験において非常に重要です。

BCPの監査を行う際、またはBCPの設計・運用を考える際、以下のポイントを整理しておくと、試験問題の読解がよりスムーズになります。

知识点总结 (BCPの要点)

- **定義：** 災害やインシデント発生時に、「すべての業務を即座に元通りにする」ことではなく、「中核となる業務 (最優先業務) を特定し、それを停止させない、あるいは早期に復旧させる」ための計画。
- **BCPの構成要素 (監査のチェックポイント)：**
 - **中核事業の特定：** 何が止まると会社が死ぬのか。
 - **目標復旧時間 (RTO) の設定：** どのくらいの時間内に戻さなければならないか。
 - **代替手段の確保：** システムが使えないなら、手作業や別の場所でどう業務を回すか。
 - **教育と訓練：** いざという時に動けるか (机上演習など)。

試験では、「BCPの監査において、何を参照すべきか？」という問いがよく出ます。

- **中小企業庁・経済産業省のガイドライン：** これらは「公的な基準」として、監査人が「現在のBCPが適切かどうか」を客観的に判断するための「**判断の尺度 (評価基準)**」となります。
- **監査人の視点：** 監査人は「会社のBCPが自分たちの都合の良いように書かれているだけではないか？」を疑い、これらのガイドラインという「外部の客観的な鏡」に照らして妥当性を検証します。

考场机械式判断技巧：

- a. 看到题目问「BCP 的目标」：
 - 脑中锁定：「中断させない (不中断)」、「早期復旧 (早期恢复)」、「中核事業 (核心业务)」。
 - 错误的干扰项：通常会说“为了保护所有业务”、“为了完全防止损害发生”（这是不可能的，BCP 承认损害会发生，重点是“继续运作”）。
- b. 看到题目问「BCP 审计的判断尺度」：

- 选「ガイドライン (指南/准则)」或「指針 (方针)」。这是审计的根基。

7. 这道题考查的是「电子表格 (Spreadsheet) 审计」中的关键控制点。

在审计中，电子表格经常被视为“最终用户计算 (EUC)”工具，由于其灵活性高、修改容易，如果缺乏严格的管控，处理逻辑 (公式、宏) 很容易出现错误。

审计电子表格的「处理逻辑准确性 (処理ロジックの正確性)」，重点在于：

- **公式的透明度与可验证性：** 逻辑不能是“黑箱”，必须经过验证。
- **变更管理：** 如果表格里写了复杂的宏或公式，必须有文档记录并经过测试，确保它没有算错。

我们来依次对比，寻找能保证“算得对”的控制手段：

- **选项 1：** “スプレッドシートの作成者と利用者が同一であること” (制作者与使用者是同一人)。
 - **解析：** 这既不是必须的，也不能保证准确性。相反，如果能实现“制作者与使用者分离” (职责分离)，反而能更好地防止单人舞弊或误操作。
- **选项 2：** “スプレッドシートのバックアップが行われていること” (正在进行备份)。
 - **解析：** 这是“可用性”和“数据完整性”的控制，与“逻辑是否正确”无关。备份只能防止数据丢失，不能防止公式写错。
- **选项 3：** “スプレッドシートのプログラムの内容が文書化され検証されていること” (电子表格中的程序/逻辑内容已被文档化并经过验证)。
 - **解析：正确答案！** 这是保证处理逻辑准确性的核心。通过文档化，审计人员可以审查逻辑设计；通过验证 (测试)，可以确认计算结果是否符合业务逻辑。
- **选项 4：** “スプレッドシートの利用者が定められていること” (已指定电子表格的使用者)。
 - **解析：** 这是“访问控制”的一部分，属于安全范畴，防止未经授权的人乱动数据，但这无法保证处理逻辑本身的数学计算是正确的。

小学生级记忆法

把「电子表格审计」想象成“检查考试试卷的解题过程”：

- 题目问的是“解题逻辑 (计算公式) 是否正确”。
- **选项 3 (正确答案)：** 老师检查你的解题步骤 (文档化) 和最终答案 (验证)，这才是判断你有没有算对的唯一标准。
- 其他选项：检查谁在考试 (选项 1/4) 或者卷子丢没丢 (选项 2)，都不能说明你算出的数学题是对的。

考场机械式判断技巧：

- a. 看到「処理ロジック (处理逻辑)」+「正確性 (准确性)」：

- b. 迅速寻找以下关键词：「検証 (验证)」、「テスト (测试)」、「文档化 (文書化)」、「承認 (审批)」。
 - c. 只要选项提到“谁用”、“备份”、“权限”，这些都是干扰项，直接跳过。
8. 这道题考查的是「IT システム管理基準」中，针对「ドキュメント (文档)」的安全管控。
- 针对文档的「漏えい (泄露)」、「改ざん (篡改)」和「不正使用 (不正当使用)」这三大风险，我们的核心目标是「保护文档的机密性与完整性」。

知识点总结

- 文档管控的三个核心方向：
 - **机密性**：防止未经授权的访问（防泄露）。
 - **完整性**：防止文档内容被非法修改（防篡改）。
 - **可用性/时效性**：确保文档处于最新状态（这是为了开发质量，但不是防泄漏的直接措施）。

选项解析与详细说明

我们来依次对比，看看哪个控制手段直接针对“泄漏、篡改、不正当使用”：

- **选项 1**：“システムの変更に伴い、ドキュメントを遅滞なく更新していること”（伴随系统变更，文档能及时更新）。
 - **解析**：这是为了保证开发质量和维护效率，防止文档与系统现状脱节，与“防泄露/篡改”关系不大。
- **选项 2**：“ドキュメントの機密性を確保するための対策を講じていること”（已采取确保文档机密性的措施）。
 - **解析：正确答案**！“机密性 (Confidentiality)”的确保包含了访问控制、权限限制、加密等手段。这些措施直接有效地防止了文档泄露、未经授权的查看（不正使用）以及非法的篡改。
- **选项 3**：“ドキュメントの標準化を行っていること”（文档标准化）。
 - **解析**：这是为了提升可读性和一致性，属于文档管理效率范畴。
- **选项 4**：“プロトタイプ型開発においても、必要なドキュメントを作成していること”（在原型开发中也创建必要的文档）。
 - **解析**：这是关于开发流程规范的控制，防止文档缺失，而不是防泄漏。

小学生级记忆法

把「文档的安全审计」**想象成**“保护你的日记本”：

- 题目问的是如何防止日记被人偷看（漏えい）、乱改（改ざん）或乱用（不正使用）。

- **选项 2 (正确答案)**：你给日记本上了一把锁，或者把它放进了保险柜，这就是“采取了确保机密性的措施”。
- 其他选项（更新及时、标准化、写日记）：这些是教你如何写好日记、记清事情，但并不能防止别人偷看你的日记。

考场机械式判断技巧：

- a. 看到「漏えい (泄露)」、「改ざん (篡改)」、「不正使用 (不正当使用)」：
 - b. 迅速在选项中寻找「機密性 (机密性)」、「アクセス制御 (访问控制)」、「暗号化 (加密)」、「物理的保護 (物理保护)」等词汇。
 - c. 如果选项中提到“更新”、“标准”、“作成”，这些通常是关于文档质量控制的，而非安全控制。
 - d. 只要安全目标是防泄露，就选“机密性”。
9. 这道题考查的是系统审计中「監査証拠 (审计证据)」的本质定义。

在审计领域，「**审计证据**」指的是为了证明审计结论（如：系统是安全的、流程是合规的）而收集到的**原始依据**。它必须是客观的、能够证明事实的“物证”或“实据”。

知识点总结

- **什么是审计证据 (Audit Evidence) ?**
 - 它是审计师进行分析、判断的**原始资料**。
 - 特征：**客观性**（不是审计师自己写的）、**可验证性**、**直接证明事实**。
- **什么不是审计证据？**
 - 审计师自己写的计划书、报告草稿、内部讨论记录，这些是“审计工作底稿”的一部分，但不是证明业务本身合规的“证据”。

选项解析与详细说明

我们来逐一比对，看看哪个才是真正的“证据”：

- **选项 ア**：“システム監査チームが監査意見を取りまとめるためのミーティングの議事録”（审计组汇总审计意见的会议纪要）。
 - **解析**：这是审计组内部讨论的记录，是审计过程产生的资料，无法证明业务系统本身是否合规。
- **选项 イ**：“システム監査チームが監査報告書に記載した指摘事項”（审计报告中列出的指摘事项）。
 - **解析**：这是审计的结果，而非证明事实的证据。指摘事项是基于证据写出来的，它本身不是证据。

- **选项 ウ：** “システム監査チームが作成した個別監査計画書”（审计组制定的个别审计计划书）。
 - **解析：** 这是审计开始前的计划文档，属于审计流程的控制文件，不是证明系统事实的证据。
- **选项 工：** “システム監査チームが被監査部門から入手したシステム運用記録”（审计组从被审计部门获取的系统运行记录）。
 - **解析：正确答案！** 系统运行记录（如日志、操作记录、访问记录）是系统实际运行状态的客观体现，直接证明了系统是否按规定运行，这是最典型、最权威的**审计证据**。

小学生级记忆法

把「审计」想象成「法庭判案」：

- **审计报告（选项 イ）** 就是判决书。
- **审计计划（选项 ウ）** 就是法官的日程表。
- **会议纪要（选项 ア）** 就是法官私下里的讨论。
- **系统运行记录（选项 工：正确答案）** 就是法庭上的**监控录像和证人证词**。只有监控录像（运行记录）才能证明“案发当时到底发生了什么”。

考场机械式判断技巧：

- a. 看到「**監査証拠 (审计证据)**」：
 - b. 迅速在选项中寻找以下关键词：「**入手 (获取)**」、「**記録 (记录)**」、「**ログ (日志)**」、「**帳票 (报表)**」、「**現物 (现物/实物)**」。
 - c. 凡是审计组“自己制作”或“内部讨论”出来的东西，通通不是证据。
 - d. **证据一定是：被审计对象自己产生且被审计师拿到了手里的东西。**
10. 这道题考查的是「IT 服务管理中的职责分离（Duty Separation）」以及「数据的完整性与正确性管控」。

当“业务部门（源头）”和“信息系统部门（处理者）”分离时，确保信息传递的准确性是关键。

知识点总结

在数据处理流程中，关键的控制点包括：

- a. **授受确认（Batch Control）：** 在数据从业务部转移到信息系统部的过程中，必须核对数量、确保无丢失。
- b. **错误处理原则：** 如果发现错误，**绝对不能私自修改**。必须退回给原起票部门，因为数据的所有权属于业务部门，只有他们才有权解释和修改业务逻辑。
- c. **结果反馈（Audit Trail）：** 处理完后，必须把结果反馈给业务部门，让他们确认数据是否准确落地。

选项解析与详细说明

我们来依次“审判”各个选项，看看哪个符合职业规范：

- **选项 1：**“業務部門が入力原票ごとの処理結果を確認できるように、処理結果リストを業務部門に送付している”（将处理结果清单送回业务部门，以便确认每一张票据的处理结果）。
 - **解析：正确答案！** 这是最基本的「相互牵制」原则。信息系统部录入数据后，业务部必须通过核对清单，确保系统里的数据和原始票据一致。这是保证数据完整性和正确性的关键步骤。
- **选项 2：**“誤りの内容が明らかなときに限り、入力担当者だけの判断で入力原票を修正し、入力処理している”（仅在错误内容明显时，由录入人员自行判断并修正）。
 - **解析：错误。** 录入人员**严禁擅自修改**业务数据。一旦修改，数据的原始性和准确性责任就混淆了。必须退回业务部门修正，并重新提交。
- **选项 3：**“入力原票は処理期日まで保管し、受領枚数の点検などの授受確認は、処理期日直前に一括して行う”（票据保管到期限前，授受确认在期限前一刻统一完成）。
 - **解析：错误。** 授受确认必须在收到票据的**当时立即进行**，而不是等到处理期日。否则万一中间丢了票据，等到最后一刻才发现就来不及了。
- **选项 4：**“入力済みの入力原票は、不正使用や機密情報の漏えいなどを防止するために、入力後直ちに廃棄する”（为防泄密，录入后立即销毁）。
 - **解析：错误。** 原始票据是审计的原始证据，**必须按照规定期限保管**。如果录入后立即销毁，一旦发生数据纠纷，就再也找不到原始证据了。

小学生级记忆法

把“数据录入工作”**想象成**“财务收银”：

- **选项 1（正确答案）：**你（系统部）收了钱（录入数据），一定要给客人（业务部）开一张收据（处理结果列表），让客人核对。这样大家都放心。
- **选项 2：**你发现客人给的钱好像多了几块，你不能自己随便拿走或改，必须退给客人让他自己改。
- **选项 3：**收到钱必须马上数清，不能等到下班再数。
- **选项 4：**原始收据必须留存备查，不能收了钱就把单据烧了。

11. 这道题考查的是系统审计师在工作中的“越位行为”。

在企业治理架构中，系统审计师的角色是“医生”和“观察者”，负责发现问题并提供建议，而不是“指挥官”或“决策者”。

知识点总结

- **审计师的职责范围：**

- **发现事实（指摘）**：客观记录系统的现状与标准之间的偏差。
- **评价影响（重要性评价）**：评估该问题对企业造成的潜在风险。
- **提出建议（改善勧告）**：告诉管理层“这块需要改进，否则会有风险”。

○ **管理层的职责范围：**

- **决策与执行（命令）**：决定“是否”改进、“何时”改进以及“怎么”改进。这是管理层的职权，如果审计师越俎代庖去“命令”，就侵犯了管理层的权力。

选项解析与详细说明

我们来依次对比，看看哪个动作超出了审计师的权限：

- **选项 1**：“改善の勧告”（提出改进建议/劝告）。
 - **解析**：这是审计师的本职工作之一。审计师通过建议，引导被审计部门优化系统。
- **选项 2**：“改善の緊急性の判断”（判断改进的紧迫性）。
 - **解析**：审计师可以根据风险水平判断问题的优先级，这是评价风险的一部分。
- **选项 3**：“改善の指摘”（指明需要改进的地方/问题点）。
 - **解析**：这是审计报告的核心，审计师必须指明哪里不合规、哪里有风险。
- **选项 4**：“改善の命令”（下达改进命令）。
 - **解析**：**正确答案！**“命令”意味着强制执行权。审计师没有权力强迫被审计部门去执行某个操作，执行命令是管理层（被审计部门的上级）的职权。审计师只能“建议”，不能“命令”。

小学生级记忆法

把「审计师」想象成「体检医生」：

- **指摘（选项 3）**：医生说：“你的血糖偏高。”（客观事实）
- **紧急性判断（选项 2）**：医生说：“建议你尽快处理，因为这属于比较严重的情况。”（风险评价）
- **劝告（选项 1）**：医生说：“建议你从明天开始控制饮食。”（审计建议）
- **命令（选项 4：正确答案）**：医生直接拍桌子：“你现在立刻给我去跑 10 公里！这是命令！”——这医生肯定疯了，这完全越权了！

考场机械式判断技巧：

- 审计师的原则是「提案（Suggestion）」和「支援（Support）」。
- 只要选项中带有「命令（Order）」、「決定（Decision）」、「実行（Execution）」等带有强制执行色彩的词汇，统统都是越权，都是审计考试中的错误选项。
- 审计师只负责说“该怎么办”，被审计部门负责“怎么去办”。

12. 这道题考查的是信息安全管理中的“三道防线”（有时也包括纠正/发现，这里按题目要求的四类划分）：**预防（Preventive）**、**检测（Detective）**、**恢复（Corrective/Recovery）**。

知识点总结

在安全控制中，我们将手段按发生的时间和作用分类：

- a. **预防（Preventive）**：在事故发生前，阻止其发生。例如：权限控制、物理锁、密码。
- b. **检测（Detective）**：在事故发生时或发生后，通过监控手段发现异常。例如：日志审计、IDS、报警系统。
- c. **恢复（Corrective / Recovery）**：在事故发生后，将系统带回正常状态。例如：备份恢复、灾备切换、应急预案。

选项解析与详细说明

我们来逐一分析，看看哪个是“事后救火”用的：

- **选项 1**：“オペレーターとプログラマの職務分離”（操作员与程序员的职责分离）。
 - **解析**：这是「预防（预防性）」控制。通过职责分离，在程序上线前就杜绝了舞弊的动机和机会。
- **选项 2**：“コンティンジェンシープラン”（应急预案 / 业务连续性计划）。
 - **解析**：**正确答案**！当重大事故发生（如地震、火灾、服务器全坏）时，企业依照这个计划进行应急处理和业务切换，目的是「恢复」生产力。
- **选项 3**：“パスワードの利用”（密码的使用）。
 - **解析**：这是经典的「预防（预防性）」控制，防止非授权用户登录系统。
- **选项 4**：“メッセージ認証”（消息认证 / MAC）。
 - **解析**：这是「检测（或预防）」控制。用于确保消息在传输过程中没有被篡改。如果通过计算认证码发现不匹配，则说明发生了非法篡改，属于检测范畴。

小学生级记忆法

把“系统安全”想象成“家里防火”：

- **预防（职责分离/密码）**：锁好门、不乱用明火，防止火灾发生。
- **检测（消息认证/告警）**：安装烟雾报警器，着火了立马响铃告诉你有危险。
- **恢复（应急预案/正确答案）**：真的着火了，按照家里贴的《消防逃生指南》灭火、拨打 119、从安全通道撤离，最后把屋子整理好。**这是为了让生活恢复正常的手段。**

考场机械式判断技巧：

- a. 看到「復旧 (恢复)」：

- b. 迅速寻找关键词：「プラン (计划)」、「バックアップ (备份)」、「再開 (重启/再开)」、「代用 (代替)」。
 - c. 凡是提到“防止”、“阻止”、“认证”、“分离”，这些都是在事发前的“预防”或“检测”手段。
 - d. 记住：恢复就是“救火”，计划（Plan）就是救火的说明书。
13. 这道题考察的是“代码质量保证”与“程序逻辑可靠性”的审计标准。在审计中，我们需要识别出哪个做法存在“漏网之鱼”的风险。

知识点总结

在单元测试（Unit Testing）阶段，审计的核心关注点是：**测试的覆盖率是否足够**。

- **测试的目标：** 确保程序的每一行、每一个判断分支（If-Then-Else）都能按预期工作。
- **审计禁忌：** 如果测试仅仅是“抽样调查（Sampling）”，那么未被覆盖到的代码块就极有可能隐藏着逻辑漏洞（Bug），这在金融或核心业务系统中是绝对不允许的。

选项解析与详细说明

我们来对比一下，看看哪个做法是审计师会“拍桌子”叫停的：

- **选项 ア：** “プログラマは, プログラム設計書に基づいてプログラミングを行っている”（程序员根据程序设计书进行编程）。
 - **解析：** 这是标准的开发流程，完全合规。
- **选项 イ：** “プログラマは, プログラムの全てのロジックパスの中から, サンプルングで単体テスト項目を設定している”（程序员仅从所有逻辑路径中抽样设定单元测试项）。
 - **解析：** 这就是正确答案（指摘事項/审计指摘点）！如果是核心代码，必须进行“全路径覆盖（Full Path Coverage）”测试。仅凭抽样测试意味着很多逻辑路径从未被运行过，一旦用户触发了那些隐藏路径，系统就会崩溃。这是一个严重的安全隐患。
- **选项 ウ：** “プログラミングチームのリーダーは, 単体テストの実施結果を記録し保管している”（编程团队领导记录并保管了单元测试结果）。
 - **解析：** 记录并保管测试结果是合规的表现，便于审计追溯。
- **选项 エ：** “プログラムを作成したプログラマ以外の第三者が, 単体テストを行っている”（由程序员以外的第三者执行单元测试）。
 - **解析：** 这是非常好的实践，能增强测试的客观性，防止开发者对自己的代码产生“盲点”。

小学生级记忆法

把「单元测试」想象成“批改数学考卷”：

- 题目问的是：审计师看到哪个行为会写一份“批评意见”？

- **选项 イ (正确答案)**：老师（程序员）改卷子时，嫌麻烦，只挑了最后两道大题批改，其他的题看都不看。
- 审计师（校长）看到这种行为肯定会说：“这怎么行？必须把整张试卷所有题目都检查一遍，否则漏掉错题怎么办！”

考场机械式判断技巧：

- a. 看到「**指摘事項 (需纠正事项)**」：
 - b. 迅速寻找以下词汇：「**サンプリング (抽样)**」、「**不十分 (不充分)**」、「**記録なし (无记录)**」、「**未実施 (未实施)**」。
 - c. 审计最看重的是“完整性”和“客观性”。只要行为显示出“偷懒”或“不完整”，那就是审计指摘点。
 - d. **记住：逻辑测试不允许“抽样”，必须“全覆盖”。**
14. 这道题考查的是系统审计中一种非常核心的审计技术——「**ウォークスルー法 (走查法 / 穿行测试法)**」。

ウォークスルー法 (Walk-through) 的核心逻辑是“像看电影一样跟踪数据流”。审计师通过从数据的产生到最终使用的全过程进行跟踪，来确认控制措施是否真的在按设计运行。

- **特点**：动态地追踪流程，既看书面记录（流程图），也看实际操作，从而发现流程中是否有断点或无效控制。

选项解析与详细说明

我们来依次对比，识别出真正的“走查法”：

- **选项 1**：“あらかじめシステム監査人が準備したテスト用データを監査対象プログラムで処理し...”
 - **解析**：这是「**テストデータ法 (Test Data Method)**」。审计师自己准备数据去试探系统。
- **选项 2**：“監査対象の実態を確かめるために、システム監査人が、直接、関係者に口頭で問い合わせ...”
 - **解析**：这是「**質問 (Inquiry)**」。仅仅是询问，不能作为强有力的证据。
- **选项 3**：“監査対象の状況に関する監査証拠を入手するために、システム監査人が、関連する資料及び文書類を入手し...”
 - **解析**：这是「**閲覧 (Inspection / Review)**」。通过阅读文档和账册来获取证据。
- **选项 4**：“データの生成から入力, 処理, 出力, 活用までのプロセス, 及び組み込まれているコントロールを、システム監査人が、書面上で、又は実際に追跡する。”
 - **解析：正确答案！** 这就是走查法的标准定义——跟踪从“头（生成）”到“尾（活用）”的全过程，并检查其中的“控制点（Control）”。

小学生级记忆法

把「走查法」想象成“跟着快递包裹走”：

- 审计师就像是一个快递质检员。
- **其他方法：**问问快递员流程（询问）、看看快递单据（阅览）、或者自己寄一个包裹测试（测试数据法）。
- **走查法（正确答案）：**质检员亲自跟着这个包裹，从仓库打包、物流运输、分拨中心、最后送到客户手中，看这整个过程里有没有人偷拆包裹（控制检查）。**只要跟着这一条线走完，整个流程的控制点就一目了然了！**

考场机械式判断技巧：

- a. 看到「ウォークスルー (Walk-through)」：
 - b. 迅速锁定关键词：「追跡 (追踪)」、「プロセス (流程)」、「生成から活用まで (从头到尾)」。
 - c. 如果选项里有“数据输入、处理、输出”这一连串过程，那一定是走查法。
 - d. 记住：走查法 = “跟着数据去旅行”。
15. 这道题考查的是「变更管理（Change Management）」中最核心的一环——「补丁/变更上线前的验证」。

知识点总结

在软件工程和系统运维中，「パッチ（Patch / 补丁）」本质上是一种程序的修改（变更）。任何程序修改都可能带来意想不到的“副作用”（即引入新的不具合）。

- **风险控制的核心逻辑：**在变更正式投入生产环境（本稼働）之前，必须在模拟真实环境的测试环境下，进行充分的**验证（Verification）**和**回归测试（Regression Testing）**。

选项解析与详细说明

我们来逐一分析，看看哪个选项是防止“补丁导致系统瘫痪”的有效防线：

- **选项 ア：**“キャパシティプランニングの手続を定めていること”（制定容量规划程序）。
 - **解析：**容量规划关注的是性能扩展，与补丁是否会导致程序逻辑错误无关。
- **选项 イ：**“データベース管理者が任命され、マスタデータ的管理手続を定めていること”（任命数据库管理员，并制定主数据管理程序）。
 - **解析：**这属于数据管理范畴，确保数据的一致性，而非解决补丁带来的程序不具合。
- **选项 ウ：**“ハードウェア管理台帳を作成し、システム管理者が管理していること”（创建硬件管理台账并由系统管理员管理）。
 - **解析：**这是资产管理，与软件程序的逻辑更新（补丁）无关。
- **选项 エ：**“本稼働前にシステムの動作確認を十分に実施していること”（在本机上线运行前，充分实施了系统动作确认）。

- **解析：正确答案！** 这是最直接的控制手段。通过测试（动作确认），我们能在补丁真正影响业务之前，发现它是否会导致现有系统出错，从而规避风险。

小学生级记忆法

把“补丁应用”想象成“给你的手机安装系统更新”：

- 题目问的是：怎么防止安装完更新后，手机反而卡死或没法用了？
- **选项工（正确答案）：** 厂家（开发团队）必须在发给你之前，先在成百上千台同样的手机上**试运行（动作确认）**，确认没问题了再推给你。如果你自己也是个发烧友，你也会先找台旧手机试试。
- 其他选项（容量管理、管理台账等）：这些就像是检查手机壳有没有擦干净，或者算算手机内存还有多少，虽然也是管理工作，但不能防止更新程序写得不好导致的系统崩溃。

考场机械式判断技巧：

- a. 看到「パッチ (补丁)」或「変更 (变更)」：
 - b. 迅速捕捉关键词：「テスト (测试)」、「動作確認 (动作确认)」、「承認 (审批)」、「切り戻し計画 (回滚计划)」。
 - c. 凡是提到“物理资源”、“管理台账”、“组织架构”的，通常是干扰项。
 - d. **记住：补丁管理的最高准则是“测试，测试，还是测试！”**
16. 这道题考查的是「系统审计（System Audit）的组织独立性与权威性」。

在公司治理架构中，审计规程（或审计计划）必须由具备最高决策权限的人进行审批，以确保审计工作不受任何部门的干扰，能够对公司整体负责。

知识点总结

- **为什么是“经营者”（最高管理层）？**
 - 审计的职能是向公司最高管理层（CEO、董事会等）报告风险和合规性。
 - 如果由“业务部门负责人”或“信息系统部门负责人”来审批审计规程，审计师就变成了这些部门的“下属”，审计也就失去了「独立性」，审计结果也会因为利益纠葛而失去公信力。
 - 因此，必须由凌驾于所有部门之上的「经营者」来批准，这体现了公司对审计工作的绝对支持和顶层重视。

选项解析与详细说明

我们来依次“审判”这些对象：

- **选项ア：** “監査対象システムの利用部門の長”（被审计系统的利用部门长）。
 - **解析：** 审计对象不能审批审计规程，否则就是“球员自己制订比赛规则”。

- 选项 イ：“経営者”（经营者 / 最高管理层）。
 - 解析：正确答案！作为公司最高决策者，经营者审批审计规程，确立了审计的地位，保障了其独立性。
- 选项 ウ：“情報システム部門の長”（信息系统部门长）。
 - 解析：系统部门往往是被审计方，由他们来审批审计标准，会导致“无法客观发现系统漏洞”。
- 选项 コ：“被監査部門の長”（被审计部门长）。
 - 解析：理由同上，被审计方不能拥有对审计标准和计划的审批权。

小学生级记忆法

把「审计」想象成「公司里的御史大夫（监察官）」：

- 皇帝（经营者）派御史去监察各个大臣（各部门）。
- 御史的执勤守则（审计规程），必须由皇帝（经营者）亲自盖章批准。
- 如果让宰相（信息部门长）或者地方官（业务部门长）来批准，他们肯定会把对自己不利的审计条款删掉！

考场机械式判断技巧：

- a. 看到「审计规程 (監査規程)」、「审计计划 (監査計画)」的批准者：
- b. 脑中迅速锁定「最高権限を持つ人」，也就是「经营者 (経営者)」或「董事会 (取締役会)」。
- c. 只要看到任何具体的业务部门或IT部门名字，直接排除！

17. 这道题继续考察「系统测试 (System Test)」的审计重点。

在系统测试阶段，审计师最核心的任务是确保“测试的质量”和“测试结果的真实有效性”。

知识点总结

系统测试不仅是技术开发团队的事情，它需要业务方和技术方共同参与，并且必须保证测试场景足够广泛，以覆盖各种潜在的运行错误。

选项解析与详细说明

我们来依次“审判”这几个选项：

- 选项 ア：“テストケースが網羅的に想定されていること”（测试用例被全面/网罗性地考虑到了）。
 - 解析：正确答案！这是测试质量的生命线。如果测试用例覆盖不全，比如没测到“月底结算”、“闰年”、“异常输入”等极端情况，系统上线后就会发生重大故障。因此，“网罗性（覆盖全面）”是审计测试用例时最重要的检查点。

- **选项 イ：**“テスト計画は利用者側の責任者だけで承認されていること”（测试计划仅由用户侧负责人批准）。
 - **解析：错误。**测试不仅是业务的事情，更是开发的事情。需要开发侧和业务侧共同确认、达成一致。只由单方面批准是不够的。
- **选项 ウ：**“テストは実際に業務が行われている環境で実施されていること”（测试是在实际业务运行的环境中实施的）。
 - **解析：错误。**这是极其危险的行为！如果在生产环境（本番環境）做测试，一旦出错，会导致全公司业务瘫痪。测试应当在“测试专用环境（テスト環境）”中进行，该环境应当尽可能模拟实际环境。
- **选项 エ：**“テストは利用者側の担当者だけで行われていること”（测试仅由用户侧人员执行）。
 - **解析：错误。**系统测试通常需要由技术人员进行性能测试、安全性测试等。单纯依靠业务人员测试是不够的，通常需要双方协作，甚至外包测试团队参与。

小学生级记忆法

把「系统测试审计」**想象成**“赛车比赛前的车辆检查”：

- **选项 ア（正确答案）：**你必须检查赛车的所有部位——轮胎、引擎、刹车、灯光（覆盖所有测试用例），一个都不能少，这叫“网罗性”。
- **选项 イ：**如果只有买车的人（用户）说了算，没有技师（开发）确认，那车可能根本发动不起来。
- **选项 ウ：**如果你在正式比赛的跑道（生产环境）上测试刹车，还没测试完可能就撞车了！测试应该在练习场（测试环境）进行。
- **选项 エ：**光靠驾驶员（业务用户）看是不够的，必须要有专业的维修师（开发/测试人员）同时参与。

考场机械式判断技巧：

- a. 看到「系统测试 (システムテスト)」的审计点：
- b. 迅速捕捉关键字：「網羅的 (全面/网罗性)」、「テスト環境 (测试环境)」、「共同実施 (共同实施)」。
- c. 如果看到「只由XX单方面做」或者「在生产环境做」，直接排除，这些都是典型的控制漏洞！

18. 这道题依然是在考查「システム監査人の独立性（审计师的独立性）」，这也是审计部分最核心、最容易出现的考点。

独立性的金科玉律：

- a. **禁忌一：自己审计自己**（不能审计自己所属部门，也不能审计自己负责的业务）。

b. **禁忌二：利益冲突**（与被审计对象存在直接关联，可能导致判断不客观）。

选项解析与详细说明

我们来依次“审判”，看看哪个选项触碰了“独立性”的红线：

- **选项 ア：**“監査チームメンバーに任命された総務部のAさんが、ほかのメンバーと一緒に、総務部の入退室管理の状況を監査する。”
 - **解析：正确答案（应避免的情况）！** 这是一个典型的“自己审计自己”的场景。A作为总务部的成员，去审计自己部门的入退室管理，不仅难以保持客观，还可能因为部门利益而掩盖问题。这是严重的违反独立性原则的行为。
- **选项 イ：**“監査部のBさんが、個人情報を取り扱う業務を委託している外部企業の個人情報管理状況を監査する。”
 - **解析：**完全没有问题。B是审计部的员工，外部企业是受托方，两者没有隶属关系。这是正常的审计工作。
- **选项 ウ：**“情報システム部の開発管理者から5年前に監査部に異動したCさんが、マーケティング部におけるインターネットの利用状況を監査する。”
 - **解析：**虽然C以前在系统部，但已经是5年前的事了。且目前审计的是“市场部”的互联网使用，不存在直接的利益冲突。通常认为超过一定期限（如1-2年以上）的轮岗是可以接受的。
- **选项 エ：**“法務部のDさんが、監査部からの依頼によって、外部委託契約の妥当性の監査において、監査人に協力する。”
 - **解析：**审计经常会聘请专家（如法务专家）作为“审计助手”协助工作。只要决策者是独立审计师，利用法律专家的意见来评估合同妥当性是完全合规的做法。

小学生级记忆法

把「独立性」**想象成**「运动员和裁判员」：

- **选项 ア（正确答案）：**就像是让足球比赛中的前锋（总务部）同时担任这场比赛的裁判，他在场上肯定会偏袒自己队，比赛结果完全失去了公正性。
- **选项 イ/ウ/エ：**这些情况就像是聘请专业的第三方裁判、或者向场外的规则专家咨询，这些都是合规的。

考场机械式判断技巧：

- a. 看到题目问「**独立性从避けるべき（应当避免）**」：
- b. 迅速寻找以下结构：「**自己所属部门 + 审计自己部门**」、「**以前做过的项目 + 现在审计这个项目**」。
- c. 只要看到这种“既是当事人又是裁判员”的情况，直接勾选，这就是正确答案！

19. 这道题考查的是「系统审计报告 (System Audit Report)」中对「指摘事項 (指摘事項/问题点)」的编写规范。

在审计界有一条铁律：“没有证据的结论是无效的，没有经过核实的指摘是危险的。”

知识点总结

审计报告中的“指摘事項”不仅要指出问题，还必须具备**客观性、准确性和权威性**。因此，在将其写入最终报告前，必须与被审计部门确认事实，以防止因理解偏差导致的误伤或冤案。

选项解析与详细说明

我们来依次“审判”各个选项：

- **选项 1：**“監査証拠による裏付けの有無にかかわらず...”（不论是否有审计证据支持...）。
 - **解析：错误。** 审计最重要的原则就是“客观证据”。没有证据的指摘纯属主观臆断，是审计师的大忌。
- **选项 2：**“監査対象部門の責任者が承認した事項を記載する”（仅记载被审计部门负责人批准的事项）。
 - **解析：错误。** 如果必须由“被审计方”批准才能写进报告，那审计就失去了独立性，审计师可能会因为部门负责人的阻挠而无法写出真实的问题。
- **选项 3：**“調査結果に事実誤認がないことを監査対象部門に確認した上で、監査人が指摘事項とする必要があると判断した事項を記載する。”（在与被审计部门确认调查结果无事实误认后，记载由审计师判定需要作为指摘事項的内容。）
 - **解析：正确答案！** 这是最规范的操作流程：审计师先根据证据判断这是个问题，但在写进最终报告前，必须与被审计方核对事实（确认没弄错数据、没理解错流程），最后由审计师独立决定将其写入报告。
- **选项 4：**“不備の内容や重要性は考慮せず、全てを漏れなく指摘事項として記載する”（不考虑不备内容和重要性，全部毫无遗漏地记载）。
 - **解析：错误。** 审计报告追求的是“重要性”。如果把无关紧要的琐碎问题与重大风险问题混在一起记，会淹没重点，导致管理层无法识别真正的经营危机。

小学生级记忆法

把「审计报告的编写」**想象成**「记者写新闻报道」：

- **选项 3 (正确答案)：** 记者（审计师）在刊发揭露文章之前，必须要找当事人（被审计部门）核实一下：“我写的这个数据没错吧？事情经过是这样吧？”
- **防止事实误认：** 如果记者没确认就乱发，那就是造谣；如果让当事人说了算（选项 2），那这新闻就成了广告，完全失去了揭露真相的意义！

考场机械式判断技巧：

- a. 看到「指摘事項 (指摘事項)」的编写原则：
 - b. 迅速捕捉关键字：「事实确认 (事実確認)」、「重要性 (重要性)」、「证据支持 (裏付け)」。
 - c. 如果选项中出现：“无证据”、“由被审计方批准”、“不管重不重要全部写上去”，这些全是干扰项。
 - d. 记住：写报告前，先核实事实，再筛选重要问题，最后写出来。
20. 这道题考查的是信息系统内部控制中「予防統制（预防性控制）」与「発見統制（发现性控制）」的本质区别。

知识点总结

- **予防統制 (Preventive Control)：** 在数据被输入或进入系统之前，通过各种手段“阻止”错误的发生。
 - 特点：“防患于未然”，让错误根本没机会进入系统。
- **発見統制 (Detective Control)：** 在错误已经发生或进入系统后，通过检查手段将其“揪出来”。
 - 特点：“亡羊补牢”，重点在于事后的核对与审计。

选项解析与详细说明

我们来依次对比，看看哪个选项是“事后查错”的手段：

- **选项 1：**“データ入力画面を、操作ミスを起こしにくいように設計する”（将输入画面设计为不易发生操作失误的形式）。
 - 解析：**预防控制**。这是在输入前，通过设计引导来避免错误。
- **选项 2：**“データ入力結果の出力リストと入力伝票とを照合する”（将数据录入结果的输出清单与原始输入传票进行核对）。
 - 解析：**正确答案！** 这是典型的「发现控制」。因为数据已经录入并输出了清单，核对动作是为了“发现”录入过程中是否出现了偏差或错误。
- **选项 3：**“データ入力担当者を限定し、アクセス権限を付与する”（限定录入人员并赋予访问权限）。
 - 解析：**预防控制**。在录入前，通过权限设置阻止未授权人员的操作。
- **选项 4：**“データ入力マニュアルを作成し、入力担当者に教育する”（制作录入手册，并对录入人员进行培训）。
 - 解析：**预防控制**。通过培训提高录入人员的素质，防止由于不懂业务而导致的错误。

小学生级记忆法

把「预防 vs 发现」想象成“抓坏蛋”：

- **预防（选项 1/3/4）**：你在门口装监控、安防盗门、培训保安，目的是让小偷根本进不来（不让错误发生）。
- **发现（选项 2：正确答案）**：小偷已经进屋了，你定期盘点家里东西少了没有，发现少东西了，这就是“核对”（发现错误）。

考场机械式判断技巧：

- a. 看到题目问「発見統制 (发现控制)」：
 - b. 迅速在选项中寻找以下关键词：「照合 (核对)」、「突き合わせ (匹配/对照)」、「分析 (分析)」、「点検 (点检)」、「監査 (审计)」。
 - c. 如果看到“防止”、“设计”、“限定”、“培训”、“权限”，这些统统都是为了“事先规避”，即「预防控制」。
 - d. 记住：发现控制 = 查对、检查、分析、比对。
21. 这道题考查的是「资产物理安全 (Physical Security)」和「第三方外包管理」的合规性。

在审计中，对于“备份介质（备份磁带/硬盘等）”的移交，核心风险在于：**在运输过程中，数据是否会因人为疏忽而泄露、丢失或被非法读取。**

💡 知识点总结

- **备份介质外包保管的控制要点：**
 - **加密 (Encryption)**：备份媒体必须加密，确保即使丢失也无法读取。
 - **物理防篡改/防窃取**：不能用简单的纸箱子，必须使用具备“防篡改 (Tamper-evident)”、“上锁 (Lockable)”、“运输专用容器”来装载，并确保运输过程安全可控。

🔍 选项解析与详细说明

我们来依次对比，寻找那个“不合规、存在严重安全隐患”的行为（即应作为指摘事项的选项）：

- **选项 1**：签订了检查保管状况的合同。
 - **解析**：合规。这是对供应商的持续监督。
- **选项 2**：签订了保密协议 (NDA)。
 - **解析**：合规。这是基本的合同管控。
- **选项 3**：建立了记录簿，有受领印。
 - **解析**：合规。这是典型的“授受确认”程序，确保物流链条可追溯。
- **选项 4**：“委託元担当者が、バックアップ媒体を段ボール箱に入れ、それを専門業者に引き渡している”（委托方经办人把备份媒体装进纸箱子里，交给专业机构）。

- **解析：正确答案（指摘事项/审计指摘点）！** 这是严重的物理安全违规。纸箱子（段ボール箱）极其脆弱，没有任何防盗、防窃、防丢失的功能。任何人都能随手拆开或顺走，完全无法保证介质在运输途中的安全和完整。必须使用“专用加锁容器”或具备防篡改功能的包装箱。

小学生级记忆法

把「备份媒体交付」想象成「寄送珍贵物品」：

- 题目问的是：审计师发现哪个行为是在“乱来”？
- **选项 4（正确答案）：** 就像要把金条（重要备份数据）寄出去，你却只用了一个拆快递剩下的烂纸箱子，连个胶带都不封严，这当然是“不安全行为”，审计师必须写在报告里指出这是严重的安全隐患。
- 其他选项（合同检查、NDA、记录签收）：这些都是正规的流程，审计师会夸奖它们做得好。

考场机械式判断技巧：

- a. 看到「指出事项 (指摘事項)」 + 「保管/移动」：
 - b. 迅速捕捉关键词：「没有加密 (未暗号化)」、「普通包装 (普通包装)」、「无控制措施 (対策なし)」。
 - c. 只要选项中描述的是“像寄普通快递一样处理重要数据”，那就是典型的指摘事项。
 - d. 记住：备份媒体安全 = 加密 + 专用容器 + 闭环管理。
22. 这道题考查的是 JIS Q 27002（信息安全管理实践规范）中关于「物理安全（Physical Security）」的具体要求。

审计的灵魂是“识别出那些看似方便，实则存在巨大泄露风险的漏洞”。

知识点总结

在 JIS Q 27002 的物理安全框架下，“入室控制”的核心原则是「责任可追踪性（Accountability）」。

- **合规的要求：** 对于机密区域，入室记录必须能够识别到“到底是谁”进去了。如果多人共用同一个暗码，一旦发生泄密，根本无法查出是哪个人泄的密，这在审计上属于严重的内控缺失。

选项解析与详细说明

我们来寻找那个“不合规、存在严重隐患”的选项：

- **选项 1：** “外部からの荷物の受渡しは……荷物の積降ろしができる場所で行っている”。
- **解析：** 合规。货物交付区域与核心服务器室隔离，符合物理隔离原则。
- **选项 2：** “機密性の高い情報資産が置かれている部屋には、入室許可を得た者が共通の暗証番号を入力して入室している。”（在存放高机密资产的房间，许可者使用“共通的”密码输入后进入。）

- **解析：正确答案（审计指摘点）！** 这是严重的合规漏洞。既然是“共通密码（みんな同じ番号）”，一旦泄密，根本无法判断是谁进入了房间（缺乏责任追踪）。正确的做法是使用独立的 ID 卡、指纹识别，或者每个人分配唯一的密码。

- **选项 3：**“機密性の高い情報資産が置かれる部屋は、社員以外の者の目に触れる場所を避けて設けている”。

- **解析：** 合规。这体现了“物理防窥”意识，防止外部人员直接观察到敏感区域。

- **选项 4：**“取引先との打合せは……機密性の高い情報資産が置かれていない場所で行っている”。

- **解析：** 合规。将访客区域与机密区域物理隔离，是良好的实践。

小学生级记忆法

把「共通密码（共通の暗証番号）」**想象成**“大家合用一把大门钥匙”：

- 审计师就像是安全经理。
- **选项 2（正确答案）：** 如果这栋楼里住了 50 个人，但所有人配的都是同一把钥匙，哪天大门被偷了，警察来查根本不知道是谁开的门！这在信息安全审计中是绝对禁止的。
- **审计要求：**“钥匙”必须是每个人专属的，开了门就要记录下“张三在 18:00 进入”。

考场机械式判断技巧：

- a. 看到「指摘事項 (指摘事項)」+「入室管理」：
- b. 迅速捕捉关键字：「共通 (共用)」、「無人 (无人监控)」、「未記録 (无记录)」。
- c. 任何涉及“多人共用一把钥匙/一个密码”的情况，直接勾选，这一定是错误的，因为失去了责任认定 (Responsibility) 的能力。

23. 这道题考查的是 JIS Q 27001 (ISMS/信息安全管理) 中「PDCA循环的逻辑顺序」。

在 ISMS 中，一切管理活动必须遵循“先定规矩，后执行”的严谨逻辑。如果顺序颠倒，就说明该系统的风险管理机制是“乱来”的。

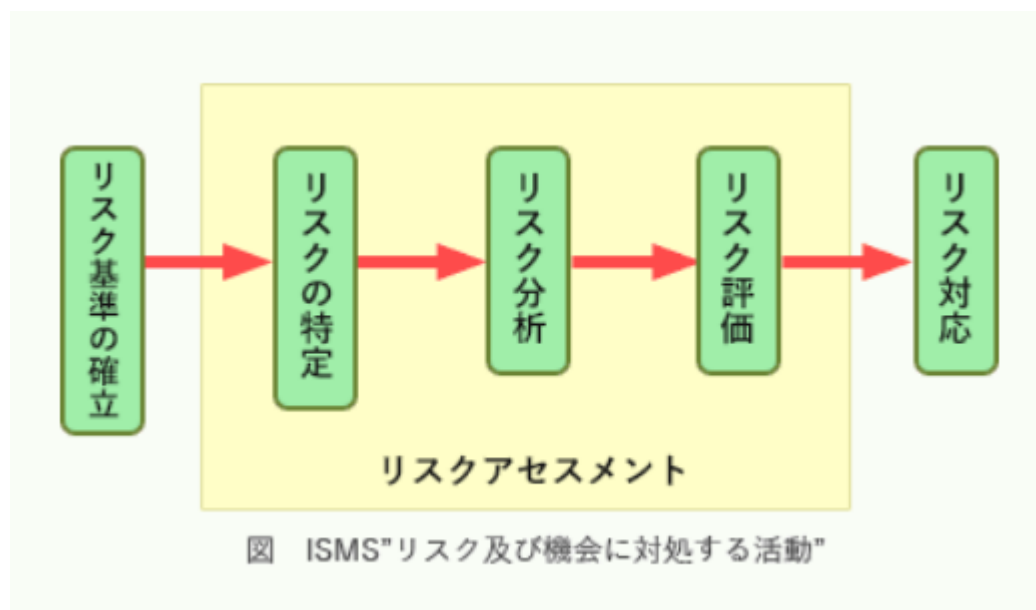
知识点总结

- **风险管理的标准步骤：**
 - i. **设定风险受容基准（风险偏好）：** 明确公司“能够承受多大风险”。
 - ii. **实施风险评估（Risk Assessment）：** 根据基准，评估具体业务的风险等级。
 - iii. **制定应对计划：** 决定怎么处理这些风险。
- **审计禁忌：** 如果在还没决定“什么风险是可以接受的（受容基準）”之前，就去强行评估风险，那这个评估的结果就没有基准，是完全无效的。

选项解析与详细说明

我们来寻找那个“逻辑错误”的操作（审计指摘点）：

- **选项 ア：**“USBメモリの使用を,定められた手順に従って許可していた。”（根据规定程序许可了USB内存的使用）。
 - **解析：** 合规。按照程序办事，符合控制要求。
- **选项 イ：**“個人情報誤廃棄事故を主務官庁などに,規定されたとおりに報告していた。”（按规定向主管官厅报告了事故）。
 - **解析：** 合规。这是事故响应流程的正确执行。
- **选项 ウ：**“マルウェアスキャンでスパイウェアが検知され,駆除されていた。”（检测到恶意软件并进行了清除）。
 - **解析：** 合规。这是安全监测与处置流程的正确执行。
- **选项 エ：**“リスクアセスメントを実施した後に,リスク受容基準を決めた。”（在实施了风险评估后，才决定了风险受容基准。）
 - **解析：** **正确答案（审计指摘点）！ 逻辑完全倒置。**你必须先设定好“标准（受容基準）”，才能拿着这个标准去“量”风险（评估）。如果先量了风险，再回头定标准，那前面的评估工作就是盲目的。这属于ISMS流程严重缺失。



🧠 小学生级记忆法

把「风险管理」想象成「设定及格分数线」：

- **正确做法：** 老师先说“60分及格”，然后大家去参加考试（评估），看谁不及格。
- **选项 エ（审计发现的错误）：** 全班同学先考完试，老师看着大家的成绩单，才突然想起来决定“到底考多少分才算及格”。这不是胡闹吗？万一你定了80分及格，那刚才考了70分的同学是不是就得重考？流程全乱套了。

考场机械式判断技巧：

- a. 看到「指摘事項(审计指摘点)」涉及「风险管理流程」：

- b. 迅速检查逻辑顺序：基准设定（第一步）->评估（第二步）->应对（第三步）。
- c. 只要出现“先评估后定标准”的，统统选它，这是审计考试中最经典的流程错误考点。
24. システム監査において、電子文書の真正性の検証に電子証明書が利用できる公開鍵証明書取得日、電子署名生成日及び検証日の組合せはどれか。なお、公開鍵証明書の有効期間は4年間とし、当該期間中の公開鍵証明書の更新や失効は考慮しない前提とする。

	公開鍵証明書取得日	電子署名生成日	検証日
ア	2014年3月1日	2016年8月1日	2020年12月1日
イ	2016年1月1日	2018年12月1日	2020年2月1日
ウ	2017年4月1日	2017年5月1日	2020年12月1日
エ	2018年8月1日	2016年7月1日	2020年3月1日

这道题考查的是「电子签名（Digital Signature）」和「公钥证书（Public Key Certificate）」在审计验证中的「时间有效性」逻辑。

💡 知识点总结

要验证电子文档的真实性，必须满足以下两个核心条件：

- 签名生成时，证书必须有效：** 电子签名的生成日期必须在公钥证书的“有效期内”。
- 证书有效期计算：** 题目规定有效期为 **4年**。这意味着，若获取日期为 X 年 M 月 D 日，则失效日期为 $X + 4$ 年 M 月 D 日。
- 验证时的要求：** 通常情况下，验证时证书本身是否过期（即验证日是否超过有效期）并不是绝对的限制（因为有时间戳等技术），但**签名生成日**绝对不能早于证书获取日，且必须在证书有效期内。

🔍 选项解析与详细说明（参考 image_851e06.png）

我们根据“有效期 = 获取日 + 4年”以及“签名生成日必须在有效期内”来核对各选项：

- **选项 ア：**
 - 有效期：2014年3月1日 ~ 2018年3月1日。
 - 签名生成日：2016年8月1日（在有效期内，符合）。
 - 但请注意：这是一个合法的签名，但我们需要看所有选项，找到最符合逻辑的。
- **选项 イ：**
 - 有效期：2016年1月1日 ~ 2020年1月1日。
 - 签名生成日：2018年12月1日（在有效期内，符合）。

- 验证日：2020年2月1日（在有效期届满后，可能存在问题）。

- **选项 ウ：**

- 有效期：2017年4月1日 ~ 2021年4月1日。
- 签名生成日：2017年5月1日（在有效期内，符合）。
- 验证日：2020年12月1日（在有效期内，符合）。
- **结论：**这是完全符合逻辑的组合，获取日期合理，签名日期在有效期内，验证日期也在有效期内。

- **选项 工：**

- 签名生成日（2016年7月1日）早于公钥证书获取日（2018年8月1日）。
- **结论：绝对错误。**不可能在获取证书之前就进行签名。

小学生级记忆法

把「电子签名」**想象成**「使用会员卡盖章」：

- 你的会员卡（公钥证书）有效期是 4 年。
- **规则 1：**你必须在领卡（获取日）之后，且在卡没过期之前，才能盖章（签名生成日）。
- **规则 2（选项 ウ）：**你在有效期内盖了章，并在卡片作废前（2021年4月前）拿去给审计师看（验证日），这套流程最完美。
- **选项 工的错误：**你在领卡前就盖了章，这是“穿越时空”的魔法，不被认可！

考场机械式判断技巧：

a. 看到「**电子签名时间逻辑题**」：

b. **第一步：**检查“**证书获取日**” <= “**签名生成日**”。如果签名早于获取日，直接排除（如选项 工）。

c. **第二步：**计算有效期（获取日 + 4年），检查“**签名生成日**”是否在该区间内。

d. **第三步：**只要逻辑自治且证书处于有效期内，即为正确答案。

25. 这道题考查的是「**用户验收测试 (UAT / ユーザー受入れテスト)**」的核心原则。

在审计 UAT 时，我们最关注的是：“**这真的是用户自己验收的吗？**” 以及 “**有没有把开发和验收的职责混淆？**”

知识点总结

- **用户验收测试 (UAT) 的本质：**

- **主体：**必须是“用户（业务部门）”，而不是开发系统的人。
- **独立性：**验收测试的目的是为了确保系统满足业务需求，因此开发部门（系统部门）不能即当“运动员”（开发）又当“裁判员”（验收）。

- **责任人：**必须由用户侧的负责人来认可验收结果。

选项解析与详细说明

我们来寻找那个“不合规、存在严重内部控制缺陷”的选项：

- **选项 1：**“システム部門だけでテストを行い、テスト結果をその責任者が承認した。”（仅由系统部门进行测试，并由该部门责任人批准结果。）
 - **解析：** **正确答案（指摘事項/审计指摘点）！** 这是严重的违规行为。让系统开发方自己测试并批准验收，相当于“裁判员自己给自己打分”。UAT 必须由用户参与，验收结论也必须由用户侧批准。
- **选项 2：**“当該業務に精通したユーザーが参画してテストを行った。”（熟悉业务的用户参与并进行了测试）。
 - **解析：** 合规。这是 UAT 的基本要求，能确保业务逻辑符合实际操作。
- **选项 3：**“ユーザー受入れテストの実施環境は本番環境と隔離させた。”（UAT 的实施环境与生产环境隔离）。
 - **解析：** 合规。这是物理安全和逻辑控制的基准。
- **选项 4：**“ユーザー要求をすべてテスト対象としたテストケースを設定した。”（针对所有用户需求设定了测试用例）。
 - **解析：** 合规。这是 UAT 覆盖率的要求，保证所有功能点都能被验收。

小学生级记忆法

把「用户验收测试」**想象成**「你买新房验收」：

- **选项 1（审计指摘点）：** 建筑商（系统部门）盖好了房，自己进去转了一圈，然后自己给自己签了一张“房子没问题”的验收单。**这在审计（业主检查）看来是绝对不可接受的！**
- **你应该做的：** 必须由你（用户）亲自带着尺子和灯泡去验房，你签字认可了，这房子才能交接。

考场机械式判断技巧：

- a. 看到「**指摘事項 (需纠正事项)**」+「**UAT (用户验收测试)**」：
 - b. 迅速捕捉关键字：「システム部門だけで (仅由系统部门)」、「**开发人员批准 (開発者の承認)**」。
 - c. 只要看到这种“剥夺用户参与权”或“让开发商自己批准”的行为，直接选它，这就是审计铁律下的“死刑犯”。
26. 在批量数据交换（Batch Data Exchange）中，最常用的预防“漏传、多传”的手段就是「**コントロールトータルチェック（控制总计检查）**」。
- 它的逻辑非常简单：

- i. **发送前：** 发送方计算出数据的“总数”（比如一共发了 100 条记录）。
- ii. **传输：** 数据包和这个“100”一起发送过去。
- iii. **接收后：** 接收方收到数据后，也数一遍，发现正好是 100 条。
- iv. **核对：** 如果两边的数字对上了，说明传输过程完整，没有丢失。

我们来对比一下这些专业术语的含义：

- **选项 1：** “アクセスコントロール”（访问控制）。
 - **解析：** 用于限制谁能访问数据，属于防泄露机制。
- **选项 2：** “エディットバリデーションチェック”（编辑校验 / 格式校验）。
 - **解析：** 用于检查单条数据的格式是否合法（如：日期是否是数字、金额是否为正数）。
- **选项 3：** “コントロールトータルチェック”（控制总计检查）。
 - **解析：正确答案！** 这就是通过核对记录总数或金额总额（Hash Total / Control Total），来确认数据在传输中是否发生丢失的手段。
- **选项 4：** “チェックデジット”（校验位）。
 - **解析：** 用于检查单项数据（如身份证号、卡号）在录入时是否输入错误，通过简单的数学公式校验合法性。

27. 这道题考查的是「系统审计（System Audit）的核心目的」。

在《系统审计基准（システム監査基準）》中，系统审计不仅仅是找错，它是一项支撑企业 IT 治理（IT Governance）的战略活动。

知识点总结

系统审计的最高宗旨是：**通过客观评估风险控制状况，促进企业 IT 治理的实现，从而确保业务目标的达成。**

- **核心逻辑：** 识别风险 → 评价控制是否有效 → 提出改善意见 → 提升企业的整体 IT 水平（即 IT 治理）。

选项解析与详细说明

我们来对比一下各选项，识别哪个是“审计的灵魂”：

- **选项 1：** “经营战略规划”（这是经营层的职责，不是审计的目的）。
- **选项 2：** “网络环境脆弱性评估”（这是技术评估，属于具体的技术手段，而非审计的宏观目的）。
- **选项 3：** “情報システムにまつわるリスクに対するコントロールの整備・運用状況を評価し、改善につなげることによって、ITガバナンスの実現に寄与する。”（通过评估与信息系统相关的风险控制的完善和运行状况，并将其与改善联系起来，从而为实现 IT 治理做出贡献。）

- **解析：正确答案！** 这句话几乎是《系统审计基准》目的部分的“教科书式定义”。它涵盖了审计的三个核心要素：**评价风险控制、推动改善、支撑 IT 治理**。

○ **选项 4：**“提升开发生产力”（这是开发部门的目标，不是审计的目的）。

小学生级记忆法

把「系统审计」想象成「企业的健康检查与优化升级」：

- **选项 3（正确答案）：** 审计师就像是健康专家，他不仅仅检查你哪儿疼（风险），还会评估你现在的锻炼计划（控制）行不行，并建议你如何调整（改善），最终目的是让你成为一个“健康的企业”（IT 治理），能够跑得更快、走得更远。

考场机械式判断技巧：

- a. 凡是题目问「**审计的目的 (目的)**」：
 - b. 迅速寻找关键词组合：「**リスク (风险)**」+「**コントロール (控制)**」+「**ITガバナンス (IT 治理)**」。
 - c. 审计的终极目的从来不是单一的技术指标（如性能、生产力），而是“让 IT 运行得更符合企业战略”（即 IT 治理）。
28. 这道题考查的是「**源代码版本管理系统 (Version Control System)**」引入后，审计重点在「**机密性 (Confidentiality)**」方面的变化。

在版本管理系统引入之前，源代码可能分散在各个程序员的电脑里。一旦引入了版本管理系统，所有核心资产（源代码）都集中在了一个平台上。因此，「**谁能看到这些代码**」成为了机密性管理中最大的风险点。

- **核心逻辑：** 源代码是企业的核心商业机密。版本管理系统是代码的“保险柜”，审计的重点在于：**是否有权限 (Access Control) 来防止未经授权的人员读取或下载代码**。

选项解析与详细说明

我们来对比一下，看看哪个是审计“机密性”的关键切入点：

- **选项 1：**“バージョン管理システムに登録したソースコードの変更結果を責任者が承認していること”（责任人批准源代码的变更）。
 - **解析：** 这是「**完整性 (Integrity)**」和「**流程合规性**」的检查点，不是机密性。
- **选项 2：**“バージョン管理システムのアクセスコントロールの設定が適切であること”（版本管理系统的访问控制设置是否适当）。
 - **解析：正确答案！** 这是机密性的核心。通过访问控制（Access Control），确保只有被授权的开发人员才能查看或获取源代码，防止非法窃取，这是保护代码机密性的第一道防线。
- **选项 3：**“バージョン管理システムの導入コストが適正な水準にあること”（导入成本是否适度）。
 - **解析：** 这是「**经济性 (Efficiency)**」的评价，与安全性（机密性）无关。

- **选项 4：**“バージョン管理システムを開発部門が選定していること”（由开发部门选定）。
 - **解析：**这是项目管理范畴，无法直接说明机密性是否得到了保障。

🧠 小学生级记忆法

把「版本管理系统」**想象成**「公司核心文件的电子保险库」：

- **选项 2（正确答案）：**保险库最重要的事情就是“钥匙在谁手里”。如果谁都能打开保险库，那里面存什么都没用。所以审计师检查的第一件事，永远是“访问控制（钥匙管理）”设置得对不对。

考场机械式判断技巧：

- a. 看到「**机密性 (機密性)**」的审计：
 - b. 脑中迅速锁定关键词：「**アクセス権限 (访问权限)**」、「**アクセスコントロール (访问控制)**」、「**認証 (认证)**」。
 - c. 只要选项里提到“权限设置”，它就是为了保护机密性。
 - d. **记住：机密性 = 权限管控。**
29. 这道题考查的是「**业务连续性管理 (BCM)**」和「**物理安全管理**」中关于「**备份介质保管**」的基本常识。

在审计中，对于备份数据的存放，有一条“不能放在一起”的铁律。

💡 知识点总结

为了确保在发生火灾、地震或洪水等自然灾害时能够成功恢复数据，备份介质（如磁带、外置硬盘）的存放必须满足以下核心原则：

- a. **异地存放 (Off-site Storage)：**备份必须与生产环境（存放服务器的地方）物理隔离。
- b. **避免同灾区风险：**如果备份存放在服务器旁边，一旦发生火灾或楼房倒塌，服务器被毁的同时，备份介质也会一起被毁。这样就失去了“备份”的意义。

🔍 选项解析与详细说明

我们来寻找那个“严重违规、会让备份彻底失效”的行为（审计指摘点）：

- **选项 ア：**“バックアップ取得手順書を作成し、取得担当者を定めていた”（制定了备份手册并指定了负责人员）。
 - **解析：**合规。这是明确的操作管理控制。
- **选项 イ：**“バックアップを取得した電子記録媒体からデータベースを復旧する試験を...実施していた”（定期实施了恢复测试）。
 - **解析：**合规。定期进行恢复测试是《信息安全管理基准》的核心要求，确保备份数据是真正可用的。

- **选项 ウ：**“機密保持を含む契約を取り交わした外部の倉庫会社に委託保管していた”（委托给了有保密协议的外部仓库进行保管）。
 - **解析：**合规。这符合异地保管的原则。
- **选项 エ：**“バックアップを取得した電子記録媒体を、業務システムが稼働しているサーバの近くで保管していた。”（把备份介质存放在运行业务系统的服务器附近。）
 - **解析：正确答案（审计指摘点）！** 这是严重的逻辑错误。如果存放服务器的机房发生了火灾、水灾或盗窃，备份介质也会同时受到破坏或丢失。这导致“单点故障”风险，完全达不到灾难恢复（DR）的要求。

小学生级记忆法

把「备份保管」想象成「家里的备用钥匙」：

- **选项 エ（审计指摘点）：** 如果你把防盗门的备用钥匙也锁在门后的挂钩上，那小偷撬开门的同时，也拿到了你的备用钥匙，这叫什么备份？
- **正确做法：** 备份必须存放在“别人家”（异地保管），这样就算你家进火灾或被搬空，备份依然安全，能帮你重建家园。

考场机械式判断技巧：

- 看到「**指摘事項 (指摘事項)**」+「**备份保管**」：
 - 迅速捕捉关键词：「**近く (附近)**」、「**同一建物内 (同一建筑物内)**」、「**没有加密 (未暗号化)**」。
 - 只要备份和生产环境在同一地点，直接勾选，这就是为了“灾难恢复”而设置的审计必考点。
30. 这道题考察的是审计师的**行为准则与职业操守**。我们需要在四个选项中，选出那个符合系统审计师角色定义（客观、专业、合规）的操作。

系统审计师的核心准则是：「**证据导向 (Evidence-based)**」、「**发现问题 (Pointing out)**」、「**独立性 (Independence)**」。

- 禁忌：** 凭主观经验（猜测）、越权行使管理权力（命令）、虎头蛇尾（随意中止调查）。
- 职责：** 指明问题，将改善的权力交还给管理层。

选项解析与详细说明

我们来依次“审判”这些行为，看看谁是专业、谁是业余：

- **选项 ア：**“調査が不十分な事項について、過去の経験に基づいて監査意見をまとめた。”（基于过去的经验，对调查不充分的事项总结了审计意见。）
 - **解析：错误。** 审计意见必须基于“充分且适当的审计证据”。仅凭经验总结意见是极不负责任的，也是审计大忌。
- **选项 イ：**“調査によって発見した問題点について、改善指摘を行った。”（针对调查中发现的问题点，进行了改善指摘。）

■ **解析：正确答案！** 这是审计师的本职工作。审计师通过调查发现问题，并将其整理为“指摘（指出的问题点）”反馈给被审计部门，这完全符合职业规范。

○ **选项 ウ：** “調査の過程で発見した問題点について, その都度, 改善を命令した。”（针对调查中发现的问题，每次都直接下达了改善命令。）

■ **解析：错误。** 老考点了！审计师只能做“建议者”，不能做“指挥官”。「命令」是管理层的职权，审计师越权就会失去公正性。

○ **选项 工：** “調査の途中で当初計画していた期限がきたので, 監査報告書の作成に移った。”（调查途中到期了，就直接开始写审计报告了。）

■ **解析：错误。** 如果调查尚未完成（存在未解之谜），审计师应该申请延长调查或在报告中明确说明“调查不充分”。如果调查没做完就写报告，报告会丧失可信度。

小学生级记忆法

把「审计师」想象成「侦探」：

- **选项 ア（凭经验瞎猜）：** 不去现场取证，靠猜案情，这不是侦探，是算命先生。
- **选项 イ（正确答案）：** 收集到证据后，写出调查结论，指出哪里不对，这是专业侦探。
- **选项 ウ（直接命令）：** 把嫌疑人直接带走审判，侦探没有执法权，这是越权。
- **选项 工（中途放弃）：** 案子没查完就交差，这侦探是在糊弄雇主。

考场机械式判断技巧：

- a. 看到「合适的行为 (適切な行為)」：
 - b. 迅速捕捉关键词：「证据 (証拠)」、「客观 (客観的)」、「指摘 (指摘/指出)」。
 - c. 凡是出现「命令」、「基于经验 (主观)」、「未完成任务」，直接排除！
31. 这道题考查的是「职责分离 (Segregation of Duties)」和「作业执行流程」的合规性。在系统审计中，防止“既当运动员又当裁判员”是永恒的考点。

知识点总结

- **核心准则：** 在任何关键业务流程（尤其是作业计划的制定）中，“计划制定者”和“最终审批者”必须是不同的人，或者至少要经过上级审批，以防止操作人员为了个人方便而擅自修改作业规范。
- **审计的铁律：** 禁止“自作自受”（自己写计划自己审批）。

选项解析与详细说明

我们来依次“审判”，找出那个违规的行为：

- **选项 ア：** “運用責任者が, オペレーターの作成したオペレーション記録を確認している。”（运营责任人确认了操作员制作的操作记录）。

- **解析：** 合规。上级对下级的行为进行定期监控，这是非常好的内控手段。
- **选项 イ：** “運用責任者が, 期間を定めてオペレーション記録を保管している。”（运营责任人规定了操作记录的保管期限）。
 - **解析：** 合规。这是记录留痕和可追溯性的基本要求。
- **选项 ウ：** “オペレーターが, オペレーション中に起きた例外処理を記録している。”（操作员记录了作业中发生的例外处理）。
 - **解析：** 合规。这是操作员的基本职责，有助于事后审计。
- **选项 エ：** “オペレーターが, 日次の運用計画を決定し, 自ら承認している。”（操作员决定了日次运用计划，并自己批准了）。
 - **解析： 正确答案（指摘事項/审计指摘点）！** 这就是典型的职责混淆。如果操作员可以随意决定每天干什么并自己批准，那么他就可能为了偷懒而跳过关键操作或修改审计路径，从而产生巨大的舞弊风险。

小学生级记忆法

把「运用管理」想象成「员工排班表」：

- **选项 エ（审计指摘点）：** 如果员工小王每天早上自己写下今天的班表，然后自己盖章批准，那他肯定每天都给自己排最轻松的活儿，甚至直接给自己放假。这显然是违反公司制度的！
- **审计要求：** 小王可以参与计划的制定，但必须由上级主管审批，或者由主管直接定计划，这是为了保证计划的公正性和严肃性。

考场机械式判断技巧：

- a. 看到「**指摘事項 (审计指摘点)**」+「**管理业务**」：
 - b. 迅速捕捉关键词：「**自ら (自己)**」、「**一人で (一个人)**」、「**承認 (批准)**」。
 - c. 只要看到“自己干活自己审批”，直接把它揪出来。在审计里，“自己审批自己”就是最大的错误。
32. 这道题考查的是系统审计中最重要的基础文档——「**監査調書 (Audit Documentation / 审计工作底稿)**」。

知识点总结

在审计中，有一句行话叫：“没有底稿，就没有审计（No documentation, no audit）”。

- **什么是監査調書？**
 - 它是审计师在审计过程中积累的所有“证据链条”。
 - 它记录了审计师到底查了什么（程序）、怎么查的（方法）、发现了什么（发现点/证据），以及得出的结论是什么。

- **核心功能：**它是审计师发表“审计意见”的唯一依据。如果没有审计调书，审计意见就是“空中楼阁”。

选项解析与详细说明

我们来依次对比，看哪个才是真正的“审计调书”定义：

- **选项 ア：**“監査人が行った監査手続の実施記録であり, 監査意見の根拠となる。”（是审计师实施审计程序的记录，也是审计意见的根据。）
 - **解析：正确答案！**这正是审计调书的核心定义。它不仅记录了做了什么，还构成了最终报告的坚实基础。
- **选项 イ：**“監査人が監査実施に当たり被監査部門に対して提出する...誓約書をまとめたものである。”（审计师向被审计部门提交的个人安全誓约书）。
 - **解析：错误。**誓约书是行政事务，不是审计调书。审计调书是用来归档审计证据的。
- **选项 ウ：**“監査人が監査の実施に利用した基準書, ガイドラインをまとめたものである。”（审计利用的准则和指南）。
 - **解析：错误。**这些是审计的“参考依据”，而不是审计师自己形成的“调书（工作记录）”。
- **选项 エ：**“監査報告書とともに公表するよう義務付けられたものである。”（义务在审计报告之外公开的文档）。
 - **解析：错误。**审计调书通常是内部保密文档，审计师通常只需要公开最终的“审计报告”，不需要把工作底稿公之于众。

小学生级记忆法

把「审计调书」**想象成**「侦探的办案日志」：

- 警察（审计师）破案后，要写出一份总结报告（审计报告）。
- 但报告里的内容是怎么来的？就是靠这一本本厚厚的办案日志（审计调书）来证明。
- 里面记录了：“我在哪天在哪监控了嫌疑人”、“搜集到了什么物证（证据）”。如果没有这份日志，谁会相信警察写的总结报告是真的呢？

考场机械式判断技巧：

- 看到「監査調書 (Audit Documentation)」：
- 迅速捕捉关键词：「証拠 (证据)」、「実施記録 (实施记录)」、「根拠 (根据)」。
- 只要看到底稿是作为“审计意见的来源/根据”出现的，那就是正确答案。
- 记住：审计调书 = 审计师的“工作证据仓库”。

33. 这道题考查的是「基于风险的审计 (Risk-Based Audit)」的核心逻辑。

在现实工作中，审计资源（审计师的时间、预算）总是有限的，而需要审计的系统却非常多。因此，审计师必须把有限的“子弹”打在最重要的地方。

知识点总结

- 风险评估的核心公式：
 - $\text{风险程度} = \text{发生可能性 (Likelihood)} \times \text{影响程度 (Impact)}$
- 审计对象的优先级：
 - 审计师应该优先选择那些一旦出事，会对公司经营造成巨大打击（影响大）且发生概率较高的系统进行重点审查。
 - 这就是所谓的“好钢用在刀刃上”。

选项解析与详细说明

我们来依次对比，看看哪种选择方式最符合逻辑：

- 选项 ア：“运用开始时间的顺序，覆盖所有系统”。
 - 解析：这是“轮流值班制”，完全不看风险，效率极低。
- 选项 イ：“根据审计体制，挑选能实施的系统”。
 - 解析：这是“柿子专挑软的捏”，完全忽略了那些真正存在高风险的系统。
- 选项 ウ：“随机抽取系统”。
 - 解析：这是“抽彩票”，可能会遗漏最致命的系统风险。
- 选项 エ：“問題発生の可能性とその影響の大きなシステムを対象とする。”（以发生可能性及其影响巨大的系统为对象。）
 - 解析： **正确答案！** 这就是风险审计的精髓。优先审查那些对公司最重要、最可能出问题的系统，这是最科学的资源分配方式。

小学生级记忆法

把「审计对象选择」想象成「医院急诊室的接诊原则」：

- 选项 エ（正确答案）：急诊室医生一定会先救心脏病发作的病人（影响极大且紧迫），而不是看谁先挂号（时间顺序）或者抽签决定（无作为）。
- 审计亦是如此：财务系统、核心业务系统一旦挂掉，公司就瘫痪了，所以必须优先审计它们。

考场机械式判断技巧：

- a. 看到「基于风险的审计 (リスクアセスメントに基づく)」：
- b. 迅速捕捉关键词：「重要度 (重要性)」、「影响程度 (影響度)」、「可能性 (可能性)」。
- c. 任何提到“时间顺序”、“无作为（随机）”、“方便程度”的都是错的。
- d. 记住：风险审计 = 优先审查最危险、最关键的系统。

34. 这道题考查的是「不正竞争防止法」中关于「商业秘密（営業秘密）」的三大认定要件之一——「秘密管理性（Secret Management）」。

知识点总结

根据日本《不正竞争防止法》，要让企业的数据被法律认定为“商业秘密”并受到保护，必须同时满足三个要件：

- a. **秘密管理性**：公司采取了明确的措施，将这些数据作为秘密来管理。
- b. **有用的信息性**：这些数据确实具有商业价值（能提升经营效率等）。
- c. **非公开性**：这些数据没有进入公共领域。

其中，「秘密管理性」是审计中最容易发现问题的点。核心要求是：让相关人员能清晰地识别出哪些信息是需要保密的。

选项解析与详细说明

我们来寻找那个能体现“管理意图”和“可识别性”的操作：

- **选项 ア**：“该数据是否有助于改善经营效率”。
 - **解析**：这是“有用性”的检查点，不是管理性。
- **选项 イ**：“当該データの記録媒体に秘密を意味する表示をしていること”（在存放该数据的记录媒体上标注了代表秘密的标识）。
 - **解析**： **正确答案**！这是最直观的“秘密管理性”证明。通过标注（如盖上“社外秘”或“机密”章），公司明确告知了接触该介质的人：“这是秘密，不能外传”。如果没有这种标识，员工可能无意中就会把机密文件处理为废纸。
- **选项 ウ**：“定期确认内容是否刊载在出版物中”。
 - **解析**：这是“非公开性”的检查点。
- **选项 エ**：“是否违背公序良俗”。
 - **解析**：与商业秘密的法律定义无关。

小学生级记忆法

把「秘密管理性」想象成「家里的私人物品」：

- **选项 イ（正确答案）**：你在抽屉贴了个条子写着“私人物品，禁止乱动”，这就是一种“秘密管理”。如果没贴条子，别人以为是公用的随便拿去用，那在法律上就很难认定这是你的私人物品。
- **要点**：只要有这个“标签”，就是告诉所有人，我有意愿把它藏起来，这就是管理的核心。

考场机械式判断技巧：

- a. 看到「営業秘密管理指針（商业秘密管理指南）」+「秘密管理性」：

- b. 迅速捕捉关键词：「表示 (标注)」、「物理的制限 (物理限制/上锁)」、「访问权限 (权限控制)」。
 - c. 如果选项提到“盖章”、“贴条”、“上锁”、“加密”、“受限”，这就是在证明该信息被妥善管理了。
 - d. 记住：秘密管理性 = 让人一眼看出这是机密（标注）+ 限制接触（权限/上锁）。
35. 这道题考查的是「远程办公 (Teleworking / Telecommuting)」环境下的「终端设备安全管理 (Endpoint Security)」。

审计师的核心职责之一就是“从看似宽松的”制度中揪出那些会让整个公司陷入安全灾难的漏洞。

知识点总结

在远程办公场景下，企业必须对连接进来的终端设备采取「强制性的、最低限度的安全基线」。

◦ 安全黄金定律：

- i. **防御手段必须强制：** 不能把“装不装杀毒软件”这种事交给个人判断。因为一旦某个员工判断错误（比如为了省资源不装），他电脑里的病毒就会通过VPN通道直接进入公司内网。
- ii. **安全性是底线：** 任何涉及安全性的防护措施（如防病毒、操作系统补丁），必须由公司统一配置并强制执行。

选项解析与详细说明

我们来寻找那个“严重危害公司安全”的指摘点（违规行为）：

- **选项 1：** “基于规定，所有员工均可利用”。
- **解析：** 合规。前提是所有员工都受规程约束，这是正常的制度设计。
- **选项 2：** “限定使用A社发放的PC”。
- **解析：** 非常合规。这是最推荐的做法（Company-Issued PC），能确保设备受控。
- **选项 3：** “テレワーキングで使用するPCへのマルウェア対策ソフト入の要不要は、従業員それぞれが判断する。”（远程办公用PC是否需要安装恶意软件防护软件，由员工个人判断。）
- **解析：正确答案（指摘事项/审计指摘点）！** 这是极度危险的行为。杀毒软件是企业内网安全的基础防火墙，绝不能交给非专业人士（个人员工）来判断。如果让员工自己选，一旦有人不装，企业网就成了“筛子”。必须强制安装！
- **选项 4：** “严禁员工家人使用工作用PC”。
- **解析：** 合规。这是防止非法访问和信息外泄的必要控制手段。

小学生级记忆法

把「公司内网安全」想象成「防御城堡」：

- **选项 3（审计指摘点）：** 公司是城堡，VPN 是吊桥。现在你告诉大家：“吊桥防卫要不要装盾牌（杀毒软件），你自己看着办。”
- **后果：** 肯定会有几个大意的士兵（员工）不带盾牌，结果敌人的冷箭（病毒/木马）顺着吊桥射进城堡，整个公司网络就瘫痪了！**安全标准永远是公司定的，而不是员工定的。**

考场机械式判断技巧：

- a. 看到「指摘事項 (审计指摘点)」 + 「远程办公/移动设备」：
 - b. 迅速寻找：「由员工个人判断 (自己判断)」、「不进行更新 (更新しない)」、「使用未管理设备 (未管理デバイス)」。
 - c. 任何将“安全措施”交给“个人意志”的选项，都是审计违规的标志。
 - d. 记住：**安全措施 = 公司强制统一标准，拒绝个人自由化。**
36. 在审计考试中，你必须牢牢记住一点：**审计师是“评价者”和“记录者”，绝对不是“制定者”或“执行者”。**

审计师的职责边界如下：

- **可以做（适当）：** 收集证据（閲覧/查看）、记录事实（作成/制作记录）、评价风险（評価/评价）。
- **不可以做（越权）：** 制定策略（制定）、实施具体管理流程（实施）、代替管理层执行业务（運用）。

我们来依次“审判”这几个选项，看看谁做了审计师该做的事：

- **选项 1：** “ソフトウェアに関するアクセス制御の管理台帳を作成し, 保管した。”（制作并保管了软件访问控制管理台账）。
 - **解析：错误。** 台账应该是被审计方（管理部门）制作和维护的。审计师去制作“管理台账”，这叫“代替执行管理职责”，完全越权了。
- **选项 2：** “データに関するアクセス制御の管理規程を閲覧した。”（查阅了数据访问控制的管理规程。）
 - **解析：正确答案！** 这是审计师的标准动作。通过“查看文档”、“收集证据”来评估现有控制是否合规，这是最典型的审计行为。
- **选项 3：** “ネットワークに関するアクセス制御の管理方針を制定した。”（制定了网络访问控制的管理方针）。
 - **解析：错误。** 制定方针是管理层的职责。如果审计师帮你制定了方针，那他之后怎么审计？他不可能自己审计自己制定的方针（失去了独立性）。
- **选项 4：** “ハードウェアに関するアクセス制御の運用手続を実施した。”（实施了硬件访问控制的运作程序）。
 - **解析：错误。** 执行运作程序是操作员的工作。审计师去“实施业务”，属于完全越位。

小学生级记忆法

把「审计师」想象成「考官」：

- **选项 2（正确答案）**：考官的工作是看学生（被审计方）的答卷（查看规程），从而评价他做得对不对。
- **选项 1/3/4**：如果考官直接跑进教室帮学生写作业（制定方针/制作台账/亲自执行业务），那考试就完全失效了。

考场机械式判断技巧：

1. 凡是题目问「**审计师的合适行为**」：
2. 迅速捕捉动作词：「**查阅 (閱覽)**」、「**询问 (質問)**」、「**观察 (觀察)**」、「**核对 (照合)**」。
3. 凡是出现「**制定 (制定)**」、「**实施 (实施)**」、「**作成 (制作管理文件)**」，这些全都是**错误项**（因为那是被审计部门干的活儿）。